

Latest SQL Vulnerabilities

This time let's discuss a vulnerability that does not have a CVE and does not require a direct exploit. The process can get the **NTLMv2** hashes by interacting with the MSSQL server. However, we should mention again that this is a direct connection to the MSSQL server and vulnerable web applications. However, we will only focus on the process being, namely the direct interaction.

The Concept of the Attack

We will focus on the undocumented MSSQL server function called **xp_dirtree** for this vulnerability. This function returns the contents of a specific folder (local or remote). Furthermore, this function provides some additional parameters. These include the depth, how far the function should go in the folder, and the actual target folder.

The Concept of Attacks



Step XP_DIRTREE

1. The source here is the user input, which specifies the function and the folder shared in the network.
2. The process should ensure that all contents of the specified folder are displayed to the user.
3. The execution of system commands on the MSSQL server requires elevated privileges with which the service executes the commands.
4. The SMB service is used as the destination to which the specified information is forwarded.

This is when the cycle starts all over again, but this time to obtain the NTLMv2 hash of the MSSQL service.

Steal The Hash

Step Stealing the Hash

5. Here, the SMB service receives the information about the specified order through the previous process of the MSSQL service.
6. The data is then processed, and the specified folder is queried for the contents.
7. The associated authentication hash is used accordingly since the MSSQL running user queries the service.
8. In this case, the destination for the authentication and query is the host we control and the shared folder on the network.

Finally, the hash is intercepted by tools like [Responder](#), [WireShark](#), or [TCPDump](#) and displayed to us, which serves its intended purposes. Apart from that, there are many different ways to execute commands in MSSQL. For example, a common way would be to execute Python code in a SQL query. We can find more about this in the [documentation](#) from Microsoft. Other possibilities of what we can do with MSSQL will be discussed in another module.

[< Previous](#)[Next >](#)

+10 Streak

[📄 Cheat Sheet](#)[☰ Resources](#)

SQL Databases

 Attacking SQL Databases

[Latest SQL Vulnerabilities](#)

RDP

 Attacking RDP

Latest RDP Vulnerabilities

DNS

 Attacking DNS

Latest DNS Vulnerabilities

SMTP

 Attacking Email Services

Latest Email Service Vulnerabilities

Skills Assessment

 Attacking Common Services - Easy

 Attacking Common Services - Medium

 Attacking Common Services - Hard

My Workstation

O F F L I N E

 Start Instance

∞ / 1 spawns left